`X-Content-Type-Options`	Set to `nosniff` to prevent the browser guessing the correct Content-Type.	Without this header, the browser may ignore your `Content-Type` header and guess (sniff) what the content really is. This can cause JSON output to be interpreted as HTML or JavaScript, so always add this header.
`X-Frame-Options`	Set to `deny` to prevent your API responses being loaded in a frame or iframe.	In an attack known as *drag 'n' drop clickjacking*, the attacker loads a JSON response into a hidden iframe and tricks a user into dragging the data into a frame controlled by the attacker, potentially revealing sensitive information. This header prevents this attack in older browsers but has been replaced by Content Security Policy in newer browsers (see below). It is worth setting both headers for now.
`Cache-Control` and `Expires`	Controls whether browsers and proxies can cache content in the response and how long for.	These headers should always be set correctly to avoid sensitive data being retained in the browser or network caches. For most APIs, a Cache-Control value of `private, max-age=0` will ensure that the content is only cached by the browser and should be considered stale immediately (requiring the browser to check with the API if it can reuse the cached value or not). It can be useful to set default cache headers in a `before()` filter, to allow specific endpoints to override it if they have more specific caching requirements.

Modern web browsers also support the `Content-Security-Policy` header (CSP) that can be used to reduce the scope for XSS attacks by restricting where scripts can be loaded from and what they can do. CSP is a valuable defense against XSS in a web application. For a REST API many of the CSP directives are not applicable but it is worth including a minimal CSP header on your API responses so that if an attacker does manage to exploit an XSS vulnerability they are restricted in what they can do. Table 2.2 lists the directives that are recommended for a REST API. The recommended header for a REST response is:

```
Content-Security-Policy: default-src 'none';
[CA] frame-ancestors 'none'; sandbox
```